API and Third-Party Integration Security Policy

Policy ID: POL-API-004 | Version 1.0 | Classification: Internal

Policy Owner	CISO / VP Engineering	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy establishes security, privacy, lifecycle, and supplier requirements for APIs and external integrations. It is intended to prevent unauthorized access, data leakage, broken object authorization, insecure credential handling, dependency compromise, excessive trust, and unmanaged data exchange between enterprise systems and external parties.

2. Scope

This policy applies to REST, GraphQL, gRPC, SOAP, WebSocket, event/webhook, message-queue, file-transfer, EDI, SDK, plugin, OAuth/OIDC, service-to-service, and vendor integrations operated or consumed by the enterprise. It applies to both internal and external APIs where misuse could affect enterprise or customer data.

3. Governance, Accountability, and Roles

API Owners. Maintain API classification, authentication model, schemas, access rules, lifecycle, documentation, and security tests.

Integration Owners. Validate supplier trust, scopes, data flows, failure modes, credential handling, and termination procedures.

Security Architecture. Reviews high-risk and Internet-facing integrations; defines gateway and testing controls.

Third-Party Risk / Privacy. Assesses suppliers, processing arrangements, transfer implications, and contractual safeguards.

4. Policy Rules and Mandatory Guidelines

- Every API MUST have a named owner, documented purpose, consumer population, authentication method, data classification, version, and retirement plan.
- Authentication and authorization are Mandatory for non-public APIs. Anonymous access is permitted only for intentionally public, read-only information approved by the data owner.
- APIs MUST enforce authorization server-side for every operation and object. Possession of a valid token does not imply authorization to every tenant, account, record, function, or administrative action.
- Multi-tenant APIs MUST enforce tenant isolation using trusted server-side identity context. Tenant identifiers supplied by clients MUST never be accepted as sufficient authorization evidence.
- Third-party integrations MUST receive only the minimum data and privileges required. Broad 'all data' scopes are prohibited when granular scopes are technically available.

- API keys, client secrets, signing keys, and webhook secrets MUST be treated as credentials. They MUST NOT be embedded in source code, mobile applications, browser JavaScript, public documentation, tickets, or chat messages.
- Third parties MUST NOT be given shared employee credentials or interactive VPN access as a substitute for a properly designed integration identity.
- Webhooks MUST be authenticated using cryptographic signatures, mTLS, or an equivalent integrity/authenticity mechanism. Source IP allowlists alone are insufficient where stronger validation is available.
- Production APIs MUST have versioning or backward-compatible change practices. Breaking changes require consumer impact analysis and controlled deprecation.
- Unapproved data scraping, undocumented private endpoints, reverse-engineered APIs, and browser automation against third-party services for production integration are prohibited unless Legal, Security, and the service owner approve the approach.

5. Technical and Coding Constraints

- External API endpoints MUST use HTTPS. TLS 1.3 is the standard for new services; TLS 1.2 is allowed only for compatibility using approved cipher suites. Plain HTTP and obsolete SSL/TLS versions are prohibited.
- OAuth 2.0/OIDC integrations MUST use current secure flows. Authorization Code with PKCE is required for public clients. Implicit flow is prohibited for new applications. Client credentials may be used for service identities only where secrets can be securely stored.
- JWTs MUST validate signature, algorithm, issuer, audience, expiration, and other required claims. Systems MUST NOT accept unsigned tokens or trust the token header to select arbitrary verification keys without validation.
- APIs MUST implement schema and type validation, size limits, rate limits, authentication throttling, and protection from common injection and deserialization weaknesses. Unknown fields SHOULD be rejected for security-sensitive operations.
- GraphQL APIs MUST enforce query depth/complexity limits, authorization at resolver/data-access layers, and introspection restrictions appropriate to exposure. GraphQL is not exempt from per-object authorization.
- Sensitive write operations SHOULD use idempotency controls where duplicate execution could create financial, account, provisioning, or privacy impact.
- CORS MUST use explicit trusted origins. Wildcard origins combined with credentials are prohibited. Security decisions MUST NOT rely on the Origin or Referer header alone.
- API responses MUST minimize data and MUST NOT expose internal stack traces, secrets, database errors, internal hostnames, or unnecessary fields. Error codes should support troubleshooting without disclosing attack-enabling details.
- API gateways or equivalent controls SHOULD centralize authentication, rate limiting, threat detection, certificate management, and observability for Internet-facing APIs. Direct bypass paths to protected backend services are prohibited unless explicitly designed and secured.
- SAST, SCA, secret scanning, and API security tests MUST be included in CI/CD for API services. Internet-facing high-risk APIs require pre-production penetration testing or equivalent adversarial security assessment after material architecture changes.

6. Operational Control Requirements

- Third-party integrations MUST be inventoried with owner, vendor, data exchanged, credentials, scopes, endpoints, contract status, and termination steps. Inactive integrations MUST be disabled.
- API access logs MUST record authentication context, endpoint, result, relevant object/tenant identifiers where safe, source context, and security events. Logs MUST avoid recording secrets or unnecessary sensitive payloads.
- Compromise or suspected compromise of an integration credential requires immediate revocation/rotation, impact analysis, and incident-response escalation.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- API inventory
- Threat models
- Security test reports
- Integration approvals
- OAuth client/scope register
- Credential rotations
- Vendor assessments
- Deprecation records

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Security may disable API clients, revoke tokens, block endpoints, or suspend integrations that create material risk. Violations may result in release blocks, access removal, mandatory redesign, disciplinary action, supplier remedies, contract termination, or incident escalation.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Exceptions require the API/integration owner, threat model, affected data, reason the standard cannot be met, compensating controls, monitoring, Security approval, and expiration. Exceptions that weaken authentication or tenant isolation require CISO-level approval.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports secure authentication, access restriction, supplier controls, secure development, network security, logging, monitoring, and change management.
NIST CSF 2.0	GV.SC supply chain; ID.AM assets/data flows; PR.AA identity and access; PR.DS data security; PR.PS platform/software security; DE.CM monitoring; RS.MI containment.
GDPR	Articles 5, 25, 28, 32 and Chapter V apply when integrations exchange personal data.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.